

THREAT INTELLIGENCE POLICY

INLINE WITH ISO 27001:2022 & SOC 2 TYPE 2

PREPARED BY



Document Name	Threat Intelligence Policy
Classification	Internal Use Only

Document Management Information

Document Title:	Threat Intelligence Policy
Document Number:	ORGANISATION-THR-INT-POL
Document Classification:	Internal Use Only
Document Status:	Approved

Issue Details

Release Date	DD-MM-YYYY
---------------------	------------

Revision Details

Version No.	Revision Date	Particulars	Approved by
1.0	DD-MM-YYYY	<Provide details of changes made on policy here>	<Provide name of Approver here>

Document Contact Details

Role	Name	Designation
Author	<Provide name of author here>	<Provide designation of author here>
Reviewer/Custodian	<Provide name of reviewer here>	<Provide designation of reviewer here>
Owner	<Provide name of owner here>	<Provide designation of owner here>

Distribution List

Name
Need Based Circulation Only



Document Name	Threat Intelligence Policy
Classification	Internal Use Only

CONTENTS

- 1. PURPOSE 4
- 2. SCOPE 4
- 3. TERMS AND DEFINITIONS 5
- 4. ROLES AND RESPONSIBILITIES 6
- 5. THREAT INTELLIGENCE SOURCES 7
- 6. THREAT INTELLIGENCE LIFECYCLE 9
- 7. INTEGRATION WITH SECURITY OPERATIONS 10
- 8. INFORMATION CLASSIFICATION & HANDLING 12
- 9. AUTOMATION & TOOLS 13
- 10. THIRD-PARTY INTELLIGENCE SERVICES 15
- 11. COMPLIANCE AND LEGAL CONSIDERATIONS 16
- 12. TRAINING AND AWARENESS 17
- 13. MONITORING, REVIEW, AND CONTINUAL IMPROVEMENT 18
- 14. ENFORCEMENT 20
- 15. POLICY COMPLIANCE AND ENFORCEMENT 22
- 16. DOCUMENT CONTROL 24



Document Name	Threat Intelligence Policy
Classification	Internal Use Only

1. PURPOSE

The purpose of this Threat Intelligence Policy is to establish a structured and proactive approach for identifying, collecting, analysing, and leveraging threat intelligence across [ORG NAME]. This policy ensures alignment with organizational objectives for risk reduction, incident prevention, and regulatory compliance.

This policy aims to:

- Enable early detection and awareness of emerging cyber threats, attack vectors, and adversarial tactics relevant to [ORG NAME]'s environment.
- Support informed decision-making in areas such as incident response, vulnerability management, risk assessment, and control implementation.
- Ensure continuous alignment with external intelligence sources including government advisories, threat feeds, industry forums, and cybersecurity communities.
- Comply with relevant regulatory and industry frameworks, including:
 - ISO/IEC 27001:2022 (specifically Control 5.7: Threat Intelligence),
 - SOC 2 Type 2 Trust Services Criteria for Security and Availability,
 - And applicable national or sectoral cybersecurity directives.

By adopting this policy, [ORG NAME] strengthens its cyber defence posture, enhances incident response capabilities, and promotes a threat-informed security culture throughout the organization.

2. SCOPE

This Threat Intelligence Policy applies to all internal teams, systems, and third parties involved in the collection, processing, dissemination, or consumption of threat intelligence within [ORG NAME].

2.1 Covered Entities

This policy applies to:

- All employees, contractors, security analysts, and incident response personnel involved in security operations.
- All departments and business units responsible for managing IT infrastructure, cybersecurity, compliance, or risk.
- Third-party vendors or managed service providers engaged in providing threat intelligence services, feeds, or analysis.



Document Name	Threat Intelligence Policy
Classification	Internal Use Only

2.2 Covered Assets and Platforms

The policy extends to:

- On-premises and cloud-hosted environments monitored for cyber threats.
- Security tools and platforms including SIEM, SOAR, IDS/IPS, EDR, TIPs, and log aggregators.
- Collaboration tools, threat data repositories, and ticketing systems used to manage intelligence workflows.

2.3 Covered Intelligence Types

The following categories of threat intelligence fall within the scope of this policy:

- Strategic, tactical, operational, and technical threat intelligence.
- Indicators of compromise (IOCs), TTPs (tactics, techniques, and procedures), malware analysis reports, and dark web monitoring data.
- Threat advisories, vulnerability bulletins, and risk alerts received from government CERTs, ISACs, and commercial providers.

2.4 Geographic Scope

This policy is applicable across all locations, geographies, subsidiaries, and regions where [ORG NAME] operates or processes data. Local regulatory requirements must be considered in the implementation of threat intelligence activities.

3. TERMS AND DEFINITIONS

Term	Definition
Threat Intelligence (TI)	Evidence-based knowledge—including indicators, context, mechanisms, and actionable insights—about existing or emerging threats that can be used to inform security decisions.
Indicator of Compromise (IOC)	Specific data artifacts (e.g., malicious IP addresses, file hashes, domains) associated with known threat activity or malicious behaviour.
Tactics, Techniques, and Procedures (TTPs)	Behavioural patterns and methods used by threat actors to plan, execute, and sustain attacks, often mapped to frameworks such as MITRE ATT&CK.
Threat Feed	A stream of structured or unstructured threat data provided by external sources (e.g., commercial vendors, ISACs, CERTs) that is used for correlation, detection, and analysis.



Document Name	Threat Intelligence Policy
Classification	Internal Use Only

Term	Definition
Threat Intelligence Platform (TIP)	A tool or platform used to aggregate, normalize, enrich, and analyse threat intelligence data from multiple sources.
Strategic Threat Intelligence	High-level insights focused on long-term threat trends, attacker motivations, geopolitical risks, and threat landscape forecasts.
Tactical Threat Intelligence	Insights on current threat actor capabilities and infrastructure (e.g., phishing kits, botnets), useful for SOC teams and defenders.
Operational Threat Intelligence	Contextual information about specific campaigns or attacks, often including timelines, attack vectors, and impacted geographies.
Technical Threat Intelligence	Detailed data such as malware signatures, exploit payloads, and indicators of compromise used for rule-based detections.
Dark Web Monitoring	Surveillance of underground forums, marketplaces, and hidden services to detect potential risks to the organization, such as data leaks or insider threats.
Threat Actor	An individual or group responsible for conducting cyber-attacks, which may include nation-state actors, cybercriminals, hacktivists, or insider threats.

4. ROLES AND RESPONSIBILITIES

Role	Responsibilities
Chief Information Security Officer (CISO)	- Owns the Threat Intelligence Policy and ensures alignment with ISMS and SOC 2 controls.- Approves threat intelligence sources and third-party providers.- Oversees integration of intelligence into incident response and risk assessments.
Information Security Team / Threat Intelligence Analysts	- Collect, curate, and analyze internal and external threat intelligence.- Monitor emerging threats, indicators, and attack trends.- Disseminate actionable intelligence to relevant teams.- Maintain threat intelligence platforms and toolsets.
Security Operations Center (SOC) Team / Incident Response Team	- Use threat intelligence for threat detection, alert enrichment, and incident triage.- Perform threat hunting based on IOC/TTP correlations.- Escalate threat intelligence findings into actionable alerts or incidents.



Document Name	Threat Intelligence Policy
Classification	Internal Use Only

Role	Responsibilities
IT / Infrastructure Teams	- Implement technical controls based on threat intelligence insights (e.g., blocking IPs/domains, patching known exploits). - Support containment and recovery based on threat actor behaviours.
Risk and Compliance Team	- Map threat intelligence inputs to risk scenarios and threat modelling. - Assess compliance implications of emerging threats. - Participate in policy reviews, audits, and risk treatment plans.
Data Protection Officer / Privacy Team (if applicable)	- Monitor threat activity related to personal data exposure (e.g., breaches, dark web leaks). - Ensure regulatory reporting requirements are met during intelligence-led incident response.
Business Unit Heads / Application Owners	- Stay informed of relevant threats to their specific domains or technologies. - Participate in incident simulations based on intelligence. - Collaborate on implementing countermeasures.
Third-Party Threat Intelligence Providers (if engaged)	- Deliver timely, relevant, and contextual threat intelligence feeds or reports. - Support correlation with internal threat data. - Ensure adherence to SLAs, licensing terms, and data privacy agreements.

5. THREAT INTELLIGENCE SOURCES

To ensure a comprehensive view of the evolving threat landscape, [ORG NAME] shall leverage a combination of internal and external sources of threat intelligence. The selected sources must be relevant, reliable, regularly updated, and contextually aligned with the organization's environment.

5.1 Internal Sources

[ORG NAME] collects threat intelligence from internal systems and operations, including:

- Security Information and Event Management (SIEM) platforms
- Intrusion Detection and Prevention Systems (IDS/IPS)
- Endpoint Detection and Response (EDR) solutions
- Vulnerability scanning and management tools



Document Name	Threat Intelligence Policy
Classification	Internal Use Only

- Firewall and proxy logs
- Incident response reports and root cause analysis findings
- Threat hunting outputs
- User behaviour analytics and access logs
- Phishing simulation and email gateway reports

5.2 External Sources

The organization shall subscribe to and integrate relevant external threat intelligence sources, such as:

- **Government and national CERT advisories**
 - e.g., CERT-IN, NCSC (UK), US-CERT
- **Industry-specific Information Sharing and Analysis Centers (ISACs)**
 - e.g., FS-ISAC, Health-ISAC
- **Global threat intelligence platforms and vendors**
 - e.g., Recorded Future, Mandiant, CrowdStrike, etc.
- **Commercial threat feeds**
 - IP/domain blacklists, malware hashes, botnet trackers
- **Open-source intelligence (OSINT) platforms**
 - e.g., Abuse.ch, AlienVault OTX, VirusTotal
- **Vulnerability databases**
 - e.g., NVD, CVE, Exploit-DB
- **Dark web monitoring services**
 - For detection of leaked credentials, data dumps, or insider threats

5.3 Source Evaluation and Validation

All threat intelligence sources must be periodically evaluated for:

- **Relevance** to [ORG NAME]'s risk profile, infrastructure, and business sector.
- **Credibility and accuracy** of intelligence provided.
- **Timeliness and frequency** of updates.
- **Licensing or usage constraints** (especially for commercial feeds).
- **Compliance with data privacy and regulatory obligations.**



Document Name	Threat Intelligence Policy
Classification	Internal Use Only

5.4 Third-Party Integration (if applicable)

Where third-party threat intelligence services are used:

- A formal vendor assessment must be completed prior to onboarding.
- The service agreement must include SLAs, breach notification terms, and data usage restrictions.
- Integration into internal systems (e.g., SIEM, TIP, SOAR) must follow secure implementation practices.

6. THREAT INTELLIGENCE LIFECYCLE

[ORG NAME] follows a structured threat intelligence lifecycle to ensure that collected data is processed, analysed, and transformed into actionable insights that support security operations and risk management.

The lifecycle is adapted from industry best practices (e.g., NIST, MITRE) and consists of the following phases:

6.1 Direction

- Define intelligence requirements based on business risk, security goals, regulatory obligations, and threat landscape.
- Identify the types of intelligence needed (strategic, tactical, operational, technical).
- Set collection priorities based on asset criticality, threat likelihood, and known vulnerabilities.

6.2 Collection

- Gather data from approved internal and external sources as defined in Section 5.
- Use automated feeds, manual research, and community sharing platforms to obtain threat data.
- Ensure collection is timely, relevant, and complies with data privacy laws and contractual limitations.

6.3 Processing

- Normalize, deduplicate, and filter raw threat data for accuracy and relevance.
- Enrich indicators using context (e.g., geolocation, threat actor group, malware family).
- Tag intelligence based on severity, confidence level, and source reliability.



Document Name	Threat Intelligence Policy
Classification	Internal Use Only

6.4 Analysis

- Correlate indicators with internal events to identify potential risks or compromises.
- Identify TTPs and attack patterns using frameworks such as MITRE ATT&CK.
- Produce intelligence reports, summaries, and threat profiles relevant to [ORG NAME]'s environment.

6.5 Dissemination

- Share actionable intelligence with relevant teams (SOC, IR, Risk, Management) through defined channels.
- Tailor content to the audience (e.g., technical IOCs for SOC; strategic summaries for leadership).
- Maintain documentation of dissemination logs and actions taken.

6.6 Feedback and Review

- Collect feedback from intelligence consumers on usefulness, clarity, and timeliness.
- Measure impact of threat intelligence on decision-making and risk reduction.
- Refine collection priorities and lifecycle processes based on feedback and incidents.

By implementing this lifecycle, [ORG NAME] ensures that threat intelligence is not only collected but transformed into meaningful insights that proactively defend against current and emerging cyber threats.

7. INTEGRATION WITH SECURITY OPERATIONS

To maximize the value of threat intelligence, [ORG NAME] shall ensure its seamless integration into operational security processes, enabling proactive detection, efficient response, and continuous risk mitigation.

The following operational areas shall incorporate threat intelligence as a core input:

7.1 Security Monitoring and Detection

- Threat intelligence shall be integrated into the Security Information and Event Management (SIEM) platform and other monitoring tools to enrich alerts and improve detection accuracy.
- Correlation rules and detection use cases shall be updated regularly based on emerging indicators of compromise (IOCs) and adversary tactics.
- Automated ingestion of curated threat feeds shall be configured where feasible to support real-time threat identification.



Document Name	Threat Intelligence Policy
Classification	Internal Use Only

7.2 Incident Response and Investigation

- The Incident Response (IR) team shall use threat intelligence to:
 - Contextualize and prioritize alerts.
 - Attribute incidents to known threat actors or campaigns.
 - Identify potential lateral movement and future attack paths.
- Threat intelligence reports and profiles shall be linked to incident records in the IR management system for end-to-end traceability.

7.3 Threat Hunting and Adversary Simulation

- The SOC or threat hunting team shall use threat intelligence to proactively search for undetected threats within the environment.
- Intelligence on known TTPs and attack chains shall guide hypothesis-driven hunts and purple team exercises.
- Threat intelligence shall also inform red team simulations and tabletop exercises to validate detection and response capabilities.

7.4 Vulnerability and Patch Management

- Threat intelligence shall be used to prioritize vulnerabilities based not only on CVSS scores but also on exploit availability, weaponization, and active threat campaigns.
- The Vulnerability Management Team shall align remediation timelines with intelligence-based risk context, focusing on high-threat CVEs and zero-day exploits.

7.5 Risk Assessment and Threat Modelling

- Threat intelligence shall feed into periodic risk assessments to identify and evaluate emerging threats relevant to [ORG NAME]'s critical assets, systems, and services.
- The Risk and Compliance Team shall incorporate intelligence into threat modelling exercises to strengthen the organization's security architecture and control design.

7.6 Reporting to Stakeholders

- Key threat trends, active campaigns, and notable risks shall be summarized in monthly or quarterly reports to be shared with:
 - Security leadership
 - Risk and compliance teams
 - Business unit owners



Document Name	Threat Intelligence Policy
Classification	Internal Use Only

- Strategic briefings may be created for executive management based on impactful threats or industry-wide developments.

8. INFORMATION CLASSIFICATION & HANDLING

To ensure threat intelligence is appropriately protected, shared, and used, [ORG NAME] shall apply classification and handling standards based on the sensitivity, source, and intended audience of the information.

8.1 Classification of Threat Intelligence

Threat intelligence data shall be classified into the following categories to govern its access, distribution, and protection:

Classification Level	Description	Access Controls
Public	Intelligence that is publicly available or sourced from open sources (OSINT) and may be shared without restriction.	Accessible to all internal staff; may be published externally.
Internal Use	Non-sensitive intelligence used for general awareness or operational context.	Access limited to relevant internal teams.
Confidential	Intelligence that contains sensitive context, organization-specific indicators, or third-party data with restrictions.	Restricted to SOC, IR, and InfoSec teams. Requires secure storage and controlled distribution.
Restricted / TLP:RED or AMBER	Highly sensitive or regulated threat data, including law enforcement reports, confidential source info, or breach-related details.	Strict access controls. Shared on a need-to-know basis only. Encrypted storage and documented dissemination required.

8.2 Traffic Light Protocol (TLP) Compliance

[ORG NAME] shall adopt the **Traffic Light Protocol (TLP)** classification (as defined by FIRST.org) when sharing or receiving threat intelligence, particularly in external or community contexts.

- TLP:RED – Not for disclosure, restricted to participants only.
- TLP:AMBER – Limited disclosure within the organization or its clients.
- TLP:GREEN – Limited to community sharing.



Document Name	Threat Intelligence Policy
Classification	Internal Use Only

- TLP:WHITE – Freely shareable information.

All shared intelligence shall respect source-designated TLP markings, and internal recipients shall be trained on TLP usage and obligations.

8.3 Secure Handling Requirements

- Classified threat intelligence shall be stored in secure systems with role-based access controls and audit logging.
- When shared via email or communication platforms, encryption and restricted channels (e.g., secure portals, secure email gateways) shall be used.
- Threat intelligence reports must include classification labels, source attribution, and handling instructions (e.g., “Do Not Forward,” “Internal Use Only”).

8.4 Retention and Disposal

- Threat intelligence data, particularly classified or sensitive content, shall be retained only for as long as operationally or legally necessary.
- Expired or obsolete intelligence shall be reviewed periodically and securely deleted in accordance with [ORG NAME]'s Data Retention and Disposal Policy.
- Any external threat feeds or intelligence subscriptions must be monitored for data retention obligations, license restrictions, or disclosure limitations.

9. AUTOMATION & TOOLS

[ORG NAME] shall leverage automation and specialized tools to improve the efficiency, accuracy, and scalability of its threat intelligence processes. Tool usage shall be aligned with operational needs, threat maturity, and compliance requirements.

9.1 Threat Intelligence Platforms (TIPs)

- If deployed, a Threat Intelligence Platform (TIP) shall be used to aggregate, enrich, and manage threat intelligence from multiple sources.
- The TIP shall support:
 - Automated ingestion of threat feeds (internal and external)
 - Deduplication, tagging, and correlation of IOCs
 - Integration with SIEM, SOAR, and case management tools
- Access to the TIP shall be restricted to trained personnel with role-based permissions.

9.2 Security Information and Event Management (SIEM)

- The SIEM shall be integrated with curated threat intelligence feeds to enrich security alerts and drive detection logic.



Document Name	Threat Intelligence Policy
Classification	Internal Use Only

- IOC-based correlation rules (e.g., IPs, domains, file hashes) shall be automatically updated based on feed subscriptions.
- The Information Security Team shall ensure regular tuning of rules and deprecation of obsolete indicators.

9.3 Security Orchestration, Automation and Response (SOAR)

- Where implemented, SOAR platforms shall automate routine threat intelligence workflows, such as:
 - Alert enrichment with contextual threat data
 - IOC validation against internal logs
 - Triggering containment actions based on confirmed intelligence
- All automated actions shall be logged, reviewed, and subject to approval workflows.

9.4 Threat Feed Management

- Only approved and validated threat feeds shall be integrated into internal systems.
- Feed performance (e.g., detection relevance, false positives) shall be reviewed quarterly.
- Licensing, update frequency, and feed retention terms must be documented and reviewed by InfoSec or Procurement.

9.5 Threat Intelligence Tools Inventory

[ORG NAME] shall maintain an inventory of all threat intelligence tools, which may include:

Tool Type	Purpose
SIEM	Correlate events with IOCs and alert on anomalies
TIP	Aggregate and manage threat data
SOAR	Automate response actions based on threat inputs
Threat Feed Aggregators	Provide curated intelligence from external sources
Threat Mapping Tools	Visualize threat actor infrastructure and TTPs
IOC Sandboxes	Validate suspicious files, URLs, and behaviors

All tools must be configured in accordance with the organization's security hardening standards, and usage must be auditable.



Document Name	Threat Intelligence Policy
Classification	Internal Use Only

10. THIRD-PARTY INTELLIGENCE SERVICES

[ORG NAME] may engage with third-party vendors to obtain curated, sector-specific, or advanced threat intelligence services to supplement internal capabilities. The use of such services shall be governed by documented criteria, security controls, and contractual safeguards.

10.1 Vendor Selection and Onboarding

- All third-party threat intelligence providers must undergo security and compliance due diligence as per the Vendor Security Policy.
- Evaluation criteria shall include:
 - Relevance and quality of threat intelligence data
 - Coverage of relevant geographies, sectors, and threat actors
 - Certification status (e.g., ISO 27001, SOC 2)
 - Historical reliability and SLA performance

10.2 Contractual and Legal Safeguards

Contracts with threat intelligence vendors must include:

- Data confidentiality and ownership clauses
- Usage limitations (e.g., redistribution, modification rights)
- Licensing compliance for shared IOCs or reports
- SLA guarantees for data freshness and availability
- Breach notification timelines and audit rights (if sensitive data is shared)

All agreements must be reviewed and approved by Legal, InfoSec, and Procurement prior to engagement.

10.3 Integration and Access Controls

- Threat feeds or dashboards provided by third-party vendors must be integrated using secure APIs or approved methods only.
- Access to third-party portals or tools shall be role-based and regularly reviewed.
- Shared content (e.g., intelligence reports) must be classified and handled in accordance with Section 8 of this policy.

10.4 Performance Monitoring and Review

- The performance of third-party threat intelligence services shall be reviewed at least annually.
- Review metrics may include:
 - Accuracy and timeliness of intelligence



Document Name	Threat Intelligence Policy
Classification	Internal Use Only

- Relevance to [ORG NAME]'s threat landscape
- Integration health and support responsiveness
- Vendors failing to meet performance expectations may be escalated for contract review or termination.

10.5 Information Sharing Considerations

- Any sharing of internal intelligence data with third-party providers must be pre-approved by the CISO or designated authority.
- The organization must ensure:
 - No sensitive or personal data is inadvertently shared
 - Shared content does not violate data protection laws (e.g., DPDP, GDPR)
 - Anonymization or obfuscation is applied where necessary

11. COMPLIANCE AND LEGAL CONSIDERATIONS

[ORG NAME] shall ensure that all threat intelligence activities are conducted in full compliance with applicable legal, regulatory, and contractual obligations. Threat data handling, sharing, and retention shall be governed by laws related to cybersecurity, privacy, and data protection.

11.1 Regulatory Compliance

Threat intelligence practices shall align with:

- **ISO/IEC 27001:2022**, specifically Control 5.7 (Threat Intelligence)
- **SOC 2 Type 2** Trust Services Criteria for Security and Availability
- **Data protection regulations**, such as:
 - India's **Digital Personal Data Protection (DPDP) Act**
 - **General Data Protection Regulation (GDPR)** (EU)
 - **HIPAA** (if applicable)
 - Any other sector-specific cybersecurity directives relevant to [ORG NAME]'s industry

11.2 Data Privacy Obligations

- Threat intelligence data must be reviewed to ensure it does not include personally identifiable information (PII) unless justified and legally permissible.
- Any intelligence involving personal data must be:
 - Collected with a lawful basis (e.g., consent, legal obligation, legitimate interest)
 - Stored securely and shared on a strict need-to-know basis



Document Name	Threat Intelligence Policy
Classification	Internal Use Only

- Retained and disposed of in line with the Data Classification and Retention Policy

11.3 Cross-Border Data Considerations

- Threat data originating from or shared with international partners shall comply with applicable data transfer regulations (e.g., GDPR cross-border transfer clauses, adequacy decisions, SCCs).
- When using cloud-based TIPs or threat feed services, [ORG NAME] shall ensure data residency and sovereignty requirements are met.

11.4 Intelligence Sharing Restrictions

- Information received through restricted or classified channels (e.g., TLP:RED or AMBER) must not be shared externally unless authorized by the originating source.
- Information shared with external parties (e.g., peers, ISACs, regulators) shall be:
 - Anonymized where necessary
 - Shared under a formal agreement or MoU
 - Tracked and logged in the Threat Intelligence Dissemination Register

11.5 Legal Hold and Disclosure Requirements

- Threat intelligence related to ongoing investigations, litigation, or regulatory inquiries shall be preserved under legal hold procedures.
- The Legal and Compliance Team shall be notified before responding to:
 - Government requests for threat data
 - Regulator inquiries or incident-related disclosures

12. TRAINING AND AWARENESS

[ORG NAME] shall promote a threat-informed security culture by providing targeted training and awareness programs on threat intelligence usage, handling, and response. These programs are essential to ensure that employees and relevant stakeholders are equipped to leverage threat intelligence effectively and responsibly.

12.1 Role-Based Awareness Programs

- All relevant personnel (e.g., SOC analysts, IR team, InfoSec staff) shall undergo periodic training on:
 - Threat intelligence lifecycle and usage
 - Interpretation of IOCs, TTPs, and threat actor profiles
 - Secure handling and classification of intelligence (e.g., TLP protocols)
 - Integration of threat data into daily workflows (e.g., triage, investigation)



Document Name	Threat Intelligence Policy
Classification	Internal Use Only

- Business unit leaders, IT teams, and risk owners shall receive contextual briefings or executive summaries of:
 - Sector-specific threats
 - Emerging risks relevant to their function
 - Required preventive actions

12.2 Tabletop Exercises and Simulations

- Threat intelligence shall be embedded into security drills and incident response simulations to:
 - Improve real-time decision-making
 - Validate threat detection and response capabilities
 - Strengthen collaboration between technical and business teams
- Scenarios shall be based on real-world intelligence (e.g., ransomware campaigns, APT activities, zero-day vulnerabilities).

12.3 Communication Channels

- Internal threat bulletins, newsletters, and security portals shall be used to:
 - Disseminate relevant threat updates
 - Share lessons learned from internal or industry-wide incidents
 - Reinforce secure practices and vigilance
- Immediate threat alerts (e.g., high-risk CVEs or credible threats to infrastructure) shall be communicated through established escalation channels and may include temporary action advisories.

12.4 Evaluation and Improvement

- Participation in threat intelligence training shall be tracked, and refresher sessions shall be conducted at least annually.
- Feedback from training and incident simulations shall be collected to improve future sessions and address knowledge gaps.
- Awareness metrics (e.g., training completion, simulated response effectiveness) shall be reported to the CISO or ISMS Committee.

13. MONITORING, REVIEW, AND CONTINUAL IMPROVEMENT

[ORG NAME] shall establish a structured process for monitoring the effectiveness of its threat intelligence practices and shall continuously enhance its threat intelligence program based on performance metrics, stakeholder feedback, and evolving threat landscapes.



Document Name	Threat Intelligence Policy
Classification	Internal Use Only

13.1 Performance Monitoring

The effectiveness of the threat intelligence function shall be measured using defined metrics, including but not limited to:

- Volume and relevance of threat indicators consumed and actioned
- Accuracy and timeliness of intelligence-driven alerts
- False positive/false negative rates from IOC correlation
- Detection and response time improvement attributable to threat intelligence
- Utilization rates of TIP/SIEM integrations

Metrics shall be reviewed quarterly and reported to the Information Security Governance Forum or Risk Committee as applicable.

13.2 Periodic Reviews

- The Threat Intelligence Policy and its implementation shall be reviewed at least **annually**, or upon any of the following triggers:
 - Emergence of new threat vectors or attack techniques
 - Changes in legal, regulatory, or contractual requirements
 - Findings from internal audits, external assessments, or incident post-mortems
 - Implementation of major tools, platforms, or organizational changes
- The review shall be led by the CISO or designated Information Security Officer, with inputs from:
 - Risk and Compliance Team
 - SOC and IR Team
 - Legal and Data Protection Team (if applicable)

13.3 Continual Improvement

- Identified gaps, inefficiencies, or missed detection opportunities shall be documented and addressed through corrective or preventive action plans.
- Recommendations from audits, threat simulations, and stakeholder feedback shall be integrated into the intelligence lifecycle.
- Emerging threat intelligence technologies, automation capabilities, and industry best practices shall be evaluated regularly to enhance maturity.

13.4 Audit and Evidence Retention

- All records related to threat intelligence ingestion, processing, dissemination, and action shall be retained for a minimum of **24 months** or longer if required by regulation or policy.



Document Name	Threat Intelligence Policy
Classification	Internal Use Only

- These records shall be made available during:
 - Internal ISMS audits
 - SOC 2 readiness or attestation reviews
 - Regulator or client assessments

14. ENFORCEMENT

[ORG NAME] recognizes that under specific and justifiable circumstances, deviations from the requirements outlined in this Threat Intelligence Policy may be necessary. In such cases, a formal exception management process shall be followed to ensure accountability, risk mitigation, and traceability.

14.1 Purpose of Exception Management

The exception process is designed to:

- Provide flexibility in cases where immediate compliance is not technically or operationally feasible.
- Ensure risks introduced by policy deviations are documented, assessed, and approved at the appropriate level.
- Enforce time-bound exceptions with compensating controls and closure plans.

14.2 Valid Exception Scenarios

Common scenarios where exceptions may be considered include:

Scenario	Examples
Temporary unavailability of threat feed integration	Delay in onboarding or renewing third-party threat intelligence services
Technical limitations in automation or enrichment tools	Legacy systems that cannot support IOC ingestion formats
Short-term resource constraints	Inability to conduct threat hunting on specific environments within defined timelines
Regulatory limitations	Restrictions on data sharing with global threat communities



Document Name	Threat Intelligence Policy
Classification	Internal Use Only

14.3 Exception Request Process

- All exception requests must be formally submitted using the **Policy Exception Request Form** or the organization's GRC platform.
- Requests must include:
 - Description of the requirement being waived
 - Business justification for the exception
 - Duration requested (with end date)
 - Risk assessment and potential impact
 - Proposed compensating controls

14.4 Approval Workflow

Risk Level	Approval Required
Low	Information Security Officer + Business Owner
Medium	CISO + Risk Manager
High / Strategic	Risk Committee or Executive Sponsor

All approved exceptions shall be logged in the **Threat Intelligence Exception Register**.

14.5 Time-Bound Validity and Review

- Exceptions shall be valid for a **maximum of 90 days** unless extended with justification.
- Active exceptions must be reviewed **monthly** to assess ongoing relevance and risk exposure.
- Expired exceptions must be either closed or formally re-submitted.

14.6 Compensating Controls

Where an exception introduces risk, equivalent or stronger controls shall be proposed. Examples include:

Original Requirement	Compensating Control
Real-time IOC ingestion via TIP	Manual upload and review of threat reports weekly
Missing threat feed API access	Subscription to curated daily threat reports



Document Name	Threat Intelligence Policy
Classification	Internal Use Only

Original Requirement	Compensating Control
Incomplete IOC correlation coverage	Prioritized threat hunting in high-risk assets

15. POLICY COMPLIANCE AND ENFORCEMENT

All employees, contractors, service providers, and relevant stakeholders involved in security operations are expected to comply with the requirements defined in this Threat Intelligence Policy. Non-compliance may expose [ORG NAME] to security threats, operational disruption, regulatory penalties, or reputational damage.

15.1 Internal Compliance Responsibilities

- All internal users accessing or managing threat intelligence platforms or data must:
 - Follow classification, dissemination, and handling procedures as outlined in this policy.
 - Avoid unauthorized sharing of threat intelligence with external parties.
 - Participate in assigned training, awareness sessions, and incident simulations related to threat intelligence.
 - Report suspected policy violations or intelligence misuse to the Information Security Team.

15.2 External Provider Compliance

- Third-party vendors supplying threat intelligence must:
 - Adhere to contractual and licensing obligations for data usage and sharing.
 - Ensure threat intelligence is accurate, up-to-date, and securely delivered.
 - Cooperate with security reviews, SLA monitoring, and audit requests as per Section 10.

Failure to comply may result in:

- Suspension or termination of services
- Withholding of payment
- Legal or regulatory escalation depending on severity



Document Name	Threat Intelligence Policy
Classification	Internal Use Only

15.3 Violations and Consequences

Violation Type	Examples	Consequences
Policy Misuse	Unauthorized sharing of TLP:RED or classified threat data	Formal warning, access revocation
Non-Participation	Refusal to attend mandatory training or simulation	Escalation to line manager or HR
Data Handling Breach	Mishandling sensitive intelligence or storing it insecurely	Disciplinary action, security incident report
Repeated Non-Compliance	Ignoring required action items from threat reports or exceptions	Suspension of duties, performance impact

All disciplinary measures will follow the organization's HR disciplinary process and code of conduct policy.

15.4 Escalation Path

Non-compliance or policy violations shall be escalated as follows:

Risk Level	Escalation To	Timeline
Low / Operational	Information Security Officer	Within 5 business days
Medium	CISO + Risk / Compliance Lead	Within 3 business days
High / Critical	Risk Committee / Executive Management	Immediate (<24 hours)

15.5 Reporting Mechanism

- Any employee or vendor may report suspected violations or misuse via:
 - The Information Security Office
 - GRC/Whistleblower platform
 - Risk and Compliance email/contact channel

All reports will be handled confidentially and investigated as per the Incident Management Policy.



Document Name	Threat Intelligence Policy
Classification	Internal Use Only

16. DOCUMENT CONTROL

This section defines the ownership, versioning, and maintenance responsibilities associated with the Threat Intelligence Policy. It ensures the policy remains current, accurate, and aligned with organizational objectives and regulatory obligations.

16.1 Ownership and Responsibility

Role	Responsibility
Policy Owner	Chief Information Security Officer (CISO)
Custodian	Information Security Manager / Threat Intelligence Lead
Approving Authority	ISMS Steering Committee / Risk Governance Board

The Policy Owner is responsible for ensuring the implementation, awareness, and effectiveness of this policy. The Custodian ensures the policy is reviewed, updated, and distributed as required.

16.2 Review Frequency

- This policy shall be reviewed **at least once annually** or earlier if:
 - There are significant changes in the threat landscape, threat intelligence tools, or operational structure.
 - New regulatory or contractual requirements are introduced.
 - Post-incident reviews identify gaps in the existing threat intelligence process.
- Review shall include inputs from the following stakeholders:
 - Information Security Team
 - Risk and Compliance
 - Legal and Data Protection Office
 - SOC / IR Leads
 - Relevant business unit representatives

16.3 Change Management and Version Control

- All updates to this policy shall be logged with:
 - Version number
 - Date of revision
 - Summary of changes



Document Name	Threat Intelligence Policy
Classification	Internal Use Only

- Approving authority
- Superseded versions shall be archived and retained for **a minimum of 5 years** for audit and reference purposes.

16.4 Communication and Distribution

- Upon approval, the updated policy shall be:
 - Published in [ORG NAME]'s internal policy repository or GRC platform.
 - Communicated via email or team channels to impacted stakeholders.
 - Incorporated into training or onboarding programs for relevant teams.
- Where applicable, third-party vendors or partners may be required to acknowledge adherence to the updated policy terms.



DID YOU FIND THIS DOCUMENT USEFUL

**FOLLOW FOR FREE INFOSEC
CHECKLISTS | PLAYBOOKS
TRAININGS | VIDEOS**



WWW.MINISTRYOFSECURITY.CO